



Device Security Standard

Lumi Education Pty Ltd · ABN 45 700 349 015 · 24 July 2026

DRAFT

ST4S item: A10 (endpoint / device security) **Related:** S7 (server/endpoint protection), EV12 §9 (endpoint OS patching) **Version:** 0.1 DRAFT · **Date:** 2026-07-24 **Status:** Draft for review — not yet signed

1. Purpose and scope

This standard defines the minimum security configuration for **every device used to do Lumi Reading work** — that is, any device from which someone can access Lumi source code, the production project (`lumi-ninc-au`, `australia-southeast1`), the admin/support mailboxes, the Firebase/GCP console, the portals, or student data. It exists so that a lost, stolen or compromised endpoint cannot become a path to child data or to the production estate.

Scope today is small and named: Lumi is operated by a single director, so the in-scope estate is the macOS build/development machine plus any iPhone/iPad used for on-device testing, store submission, or accessing Lumi accounts. Any future contractor or adviser device that touches the above is in scope from day one and must meet this standard **before** access is granted (see the Access Register, `ACCESS_REGISTER_TEMPLATE.md`, and HR onboarding, `HR_SECURITY_PACK.md` §3).

Truthfulness note. This document states the **required** posture and the evidence needed to prove it. It does **not** by itself assert that every setting below is currently applied — the settings marked "confirm" in §8 must be verified against the actual devices and evidenced (screenshots + the device register) before this standard can be treated as *in force*. Where a control is already known to be the platform default (e.g. macOS Gatekeeper/XProtect ship enabled), that is noted, but per-device confirmation is still required.

2. Principles

- **Every Lumi device is hardened, encrypted and up to date.** There is no "personal, therefore out of scope" device — the test is whether it can reach Lumi data or accounts, not who owns it.
- **The device is not a trusted perimeter.** Endpoint hardening is defence in depth *behind* the server-side controls (deny-by-default rules, server-defined authorization, MFA on privileged accounts). It reduces the blast radius of a compromised endpoint; it is not a substitute for the access controls in `ACCESS_CONTROL_POLICY.md`.
- **No shared identities.** Each person uses their own OS user account and their own credentials to each system; devices and logins are attributable to one named human.
- **Evidenced, not assumed.** Each control has a defined way to prove it is on (a screenshot, a command output, or a register entry), captured at onboarding and re-confirmed at the annual review.

3. Required device configuration

The following is the required baseline for every in-scope macOS device. Each row names how it is verified for the evidence pack.

#	Control	Requirement	How to verify (evidence)
3.1	Screen auto-lock	Display turns off / screensaver starts after ≤ 15 minutes of inactivity	System Settings → Lock Screen → "Start Screen Saver when inactive" / "Turn display off"; screenshot
3.2	Password on wake	Password required immediately (0 seconds) after sleep or screensaver begins	System Settings → Lock Screen → "Require password after..." = immediately; screenshot
3.3	Full-disk encryption	FileVault ON for the whole startup disk; recovery key stored safely (see §5)	System Settings → Privacy & Security → FileVault = On; or <code>fdsetup status</code> → "FileVault is On"; screenshot

#	Control	Requirement	How to verify (evidence)
3.4	Application firewall	macOS application firewall enabled (stealth mode on where practical)	System Settings → Network → Firewall = On; or <code>socketfilterfw --getglobalstate</code> ; screenshot
3.5	Gatekeeper	Gatekeeper enabled — only App Store / identified-developer apps run	<code>spctl --status</code> → "assessments enabled"; screenshot
3.6	XProtect / malware protection	Apple's built-in XProtect malware protection present and updating (ships enabled on macOS)	XProtect is a platform default; confirm automatic security-data updates are on (3.7)
3.7	Automatic OS updates	Automatic macOS updates + automatic security responses enabled; the OS is on a currently-supported major version receiving security updates	System Settings → General → Software Update → Automatic updates all on; screenshot; note current macOS version
3.8	Automatic app updates	App Store apps update automatically; developer toolchains (Xcode, CLI tools, Homebrew, Flutter/Dart, Node) kept current — security releases applied without undue delay (see EV12)	App Store → Automatic Updates on; screenshot. Toolchain currency tracked via the patch process (<code>EV12_PATCH_MANAGEMENT.md</code>)
3.9	No shared accounts (device)	Each person has their own OS login; no shared/guest OS account is used for Lumi work; guest account off	System Settings → Users & Groups (no shared/guest login in use); screenshot
3.10	Strong login credential	Device login password meets the Lumi credential standard (see A2), or is a passkey/biometric backed by a strong password; auto-login off	System Settings → Users & Groups → Automatic login = Off; screenshot
3.11	Find My / remote wipe	Device locatable and remote-wipeable if lost or stolen (Find My Mac / Find My iPhone)	System Settings → Apple ID → Find My = On; screenshot

Mobile (iPhone / iPad) devices used for Lumi work

Any iOS device used to access Lumi accounts, submit builds, or test on-device must additionally have: a device passcode (6+ digits / alphanumeric), Face ID / Touch ID, auto-lock ≤ 15 minutes, **data protection** (on by default when a passcode is set — hardware full-disk encryption), automatic iOS updates, and Find My iPhone enabled for remote wipe. No shared/kiosk device is used to access adult Lumi accounts. (In-app kiosk mode on classroom iPads is a separate, product-level control and is out of scope here — those are school devices, not Lumi-operator devices.)

4. Device register

A **device register** is maintained listing every in-scope device. It is the authoritative list of what must meet §3 and is reviewed at the same cadence as the access register (§7). The register itself is kept in the restricted evidence store, not in git if it contains serial numbers; only the summary/outcome is placed in the evidence pack.

Template:

Device ID / name	Type & model	OS version	Owner (named)	Encryption (FileVault/DP)	Auto-lock ≤15m + pw-on-wake	Firewall / Gatekeeper	Auto-updates	Remote wipe	Last verified	Notes
e.g. "Lumi-MBP-01"	MacBook Pro (Apple Silicon)	macOS 15.x	Nic (Director)	On	Yes / immediate	On / on	On	Find My on	2026-07-...	Primary build machine
e.g. "Lumi-iPhone-01"	iPhone	iOS 18.x	Nic (Director)	On (passcode)	Yes / immediate	n/a	On	Find My on	2026-07-...	On-device testing + store

Every row must have a corresponding evidence artefact (screenshots per §3) filed in the restricted evidence store and cross-referenced here.

5. Recovery keys and secrets

- The **FileVault recovery key** (and any iOS recovery contacts / keys) is stored in the operator's password manager or a sealed offline location — **never** in git, in the repo, in a mailbox, or in this document. This standard prints no key, serial number, or personal identifier.
- Loss of the primary device follows the incident/BCP path ([EV9_INCIDENT_RESPONSE_PLAN.md](#)): remote-wipe via Find My, then rotate any credential that was resident on the device (see the offboarding / credential-rotation steps in [HR_SECURITY_PACK.md](#) §3 and the Access Register).

6. Relationship to other controls

- Patching (EV12).** Endpoint OS and toolchain patching is governed by [EV12_PATCH_MANAGEMENT.md](#) §9; this standard supplies the *configuration* requirement (auto-updates on, supported OS version) that EV12 relies on.
- Access control (A6/A7/A13).** A hardened device is a precondition for privileged access; adding a device or a person to the estate is an access-register event ([ACCESS_REGISTER_TEMPLATE.md](#)).
- No secrets on the endpoint that matter if it's lost.** Per the release gate, no Admin credential, service-account key or unrestricted billable key lives in a client, build artifact or on the endpoint in plaintext; CI deploys keylessly via Workload Identity Federation (see [ACCESS_CONTROL_POLICY.md](#) §7). This limits what a stolen-but-encrypted device could expose.

7. Review cadence

Trigger	Action	Frequency
New device or new person	Verify §3 in full, capture evidence, add to the register before granting Lumi access	On change
Annual review	Re-confirm every register row still meets §3; refresh screenshots; retire decommissioned devices	Annual
Device lost / stolen / decommissioned	Remote-wipe, rotate resident credentials, mark the row retired with date	On event
Major OS end-of-support	Upgrade to a supported major version before it stops receiving security updates	As released

8. Supporting evidence index

Control	Evidence (to be filed by Nic)
Auto-lock ≤15m + password-immediately (3.1–3.2)	Lock Screen settings screenshot
FileVault full-disk encryption (3.3)	fdesetup status output / FileVault screenshot
Application firewall (3.4)	Firewall settings screenshot / socketfilterfw --getglobalstate
Gatekeeper (3.5)	spctl --status output
Automatic OS + security updates (3.7)	Software Update settings screenshot + current OS version
Automatic app updates (3.8)	App Store auto-update screenshot
No shared / no auto-login (3.9–3.10)	Users & Groups + login options screenshot
Remote wipe (3.11)	Find My enabled screenshot
Device register	Completed register (§4), restricted store
Related patch posture	EV12_PATCH_MANAGEMENT.md §9

Control	Evidence (to be filed by Nic)
Related access precondition	<code>ACCESS_CONTROL_POLICY.md</code> , <code>ACCESS_REGISTER_TEMPLATE.md</code>

9. Known gaps / reviewer must confirm

- **NIC — settings not yet verified.** Every control in §3 is a *requirement*, not an evidenced fact. Nic must confirm each setting is actually applied on each in-scope device and capture the screenshots/command output listed in §8. Until then this standard is not "in force" — do not submit it to ST4S as evidence of a configured endpoint.
- **NIC — device register not yet populated.** §4 is a template. Nic must complete it with the real in-scope devices (Mac(s) + any iPhone/iPad used for Lumi) and file it in the restricted evidence store.
- **NIC — screenshots for the evidence pack.** A10 evidence is the per-control screenshots/outputs; these must be captured and filed (the A2 password-policy screenshot workflow — `~/lumi-security-evidence/...` — is the model to reuse).
- **Recovery-key custody.** Confirm the FileVault recovery key is stored in the password manager / offline (per §5) and is retrievable but not exposed.
- **Toolchain-update discipline.** §3.8 asserts developer toolchains are "kept current"; confirm this is actually happening on the cadence EV12 defines, not just OS auto-updates.
- **Sign-off.** This standard requires Nic's sign-off before it is the governing document, and is only ST4S-submittable once §3 is verified and the register + screenshots exist.